

Security Requirements Common Criteria

IT-Sicherheit | 04.03.2026

Gerald Dißauer | Lecturer

A-SIT Secure Information Technology Center Austria

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

KEY PROBLEMS¹ FOR CRYPTOGRAPHIC PRODUCTS BUILD SECURITY IN

- *„Organizations make or buy their technology [...] but rarely consider ways in which [...] it [...] functions within its intended deployment environment and the unintended consequences that are possible.“²*
- *„Every component of the software system and its interfaces must be operated and sustained with organizational risk in mind.“²*
- *„There is always uncertainty about a software systems behavior“³*
- *„At the start of a development cycle we have a limited basis for determining our confidence in the behavior of the delivered system“³*
- *“Virtually every connected system will be attacked sooner or later.”⁴*

¹ Annotation: Sometimes referred to Challenges

² cf. (Mead and Woody, 2016, p. 10)

³ cf. (Woody et al., 2014, p. 3)

⁴ cf. (Ebert, 2017, p. 209)

SECURITY REQUIREMENTS

A SOFTWARE QUALITY PROBLEM

„Hard to define, impossible to measure and easy to recognize“¹

„Software is easy to criticize and hard to do. The bigger the software, the more that is true. It is thus like speech – the more you say, the easier it is for the reader to find something to criticize, and the more likely, the critic will get it wrong.“²

„Software should be fit for its purpose. [...] deliver software of sufficient quality to bring value to its users. [...] it is essential to maintain an appropriate level of quality.“³

¹ cf. (Kitchenham, 1989)

² cf. (McGraw, 2006, p. xix)

³ cf. (Humble and Farley, 2010, p. 2)

GOALS AND REQUIREMENTS DISTINGUISHED

What do you want to achieve?

“A goal is the intentional description of a characteristic feature of the system to be developed or the associated development process.”¹

“Requirements are what the software product, or hardware product, or service, or whatever you intend to build, is meant to do and to be. Requirements exist whether you discover them or not, and whether you write them down or not. Obviously, your product will never be right unless it conforms to the requirements.”²

¹ cf. (Pohl, 2008, p. 91)

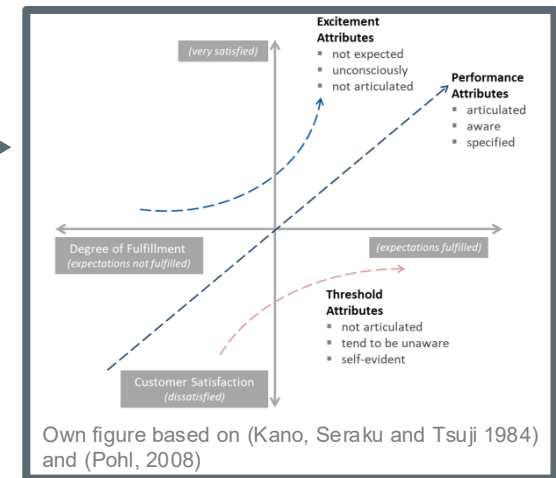
² cf. (Robertson and Robertson, 2013, p. 1)

A REQUIREMENTS PROBLEM

ACHIEVE QUALITY BY FULFILLING REQUIREMENTS

„[Quality is the] Degree to which a set of inherent¹ characteristics of an object fulfils requirements“²

- Apply Kano-Model³
- Consider best practices as baseline standards
- Engineer comprehensive security requirements
- Develop reliable software intensive systems
- Target to achieve customer satisfaction



¹ Annotation: Inherent means in terms of existing in an object

² cf. (DIN EN ISO 9000, p. 39)

³ cf. (Kano, Seraku and Tsuji, 1984)

Meet the requirements in terms of functionality and quality

Do You Use a Smartphone?

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

THE COMMON CRITERIA

WHAT IS IT?

Common Criteria (CC) for Information Technology Security Evaluation is a security standard that is used to (1) declare security requirements and (2) evaluate such requirements of software-intensive products and systems (*TOE*²) through evidence examination and product testing in particular in terms of security concerns. It is often used as a baseline which software-intensive systems can be evaluated¹.

- It is a guide³ to develop software-intensive products with security requirements
- Demands detailed documentation of software-intensive systems
- Enables the examination of products against industry standards
- Obtain unbiased results based on standardized methods

¹ Annotation: A baseline is used to define a minimum level of protection

² TOE – Target of Evaluation i.e. a software-intensive product that is investigated during the evaluation

³ Annotation: It is a guide with currently 1106 pages for the 4 reference documents in total

THE COMMON CRITERIA

WHAT IS IT? | cont'd

CC provides an acronym-heavy framework to

- Describe
- Evaluate

(cyber) security requirements of software-intensive products based upon a terminology and a structure to express both customer security requirements and vendor claims in terms of (1) functionality¹ and (2) assurance², precisely.

- The categories about protection address CIA-Triade
- We can apply CC outside of the scope of security and cryptography
- CC focuses on threats arising from human behavior but it is applicable to non"-human threats

¹ Annotation: "*Functional correctness means that the cybersecurity mechanism has to do exactly what it is supposed to do, and no more*"; cf. (Saydjari, 2018, p. 351)

² Annotation: "... without assurance, functionality could detract from system cybersecurity" cf. (Saydjari, 2018, p. 370)

THE COMMON CRITERIA FRAMEWORK

REFERENCE DOCUMENTS STRUCTURE | Nov 2022 the latest

6 Reference-Documents (*including 3 parts*) of the CC-Standard Framework:

- (1) CC Part I – Introduction and general model¹
 - (2) CC Part II – Security functional requirements²
 - (3) CC Part III – Security assurance requirements³
 - (4) Framework for the specification of evaluation methods and activities⁴
 - (5) Pre-defined packages of security requirements⁵
 - (6) Common Methodology for Information Technology Evaluation (*CEM*)⁶
- } Integrated Package of Security Requirements

¹ cf. (CCMB-2022-11-001, 2022)

² cf. (CCMB-2022-11-002, 2022)

³ cf. (CCMB-2022-11-003, 2022)

⁴ cf. (CCMB-2022-11-004, 2022)

⁵ cf. (CCMB-2022-11-005, 2022)

⁶ cf. (CCMB-2022-11-006, 2022)

COMMON CRITERIA

SOME VOCABULARY

- **Protection Profile** (*PP – the request for proposal*)
The set of security requirements associated with a class of software-intensive products independently of their current implementation to describe a needed security solution. Can be used as a normative document.
- **Security Target** (*ST – the proposal*)
The security functionality and assurance properties associated with a TOE.
- **Target of Evaluation** (*TOE – the delivered system*)
The software-intensive product that proposes a security solution that is being evaluated

COMMON CRITERIA

SOME VOCABULARY | cont'd

- **Security Functional Requirements (SFR)**
Realize functions in the products in order to achieve the security objectives of the TOE.
- **Security Assurance Requirements (SAR)**
Provide measures taken to assure compliance with the claimed security function.
- **Evaluation Deliverables**
Documentation provided to the third party evaluation office to perform the evaluation (*e.g. Development documents, functional specifications, high-level design, operational guidance*)

WHY PROTECTION PROFILES?

SOME SELECTED BENEFITS

Benefits of Security Requirements consolidated in Protection Profiles

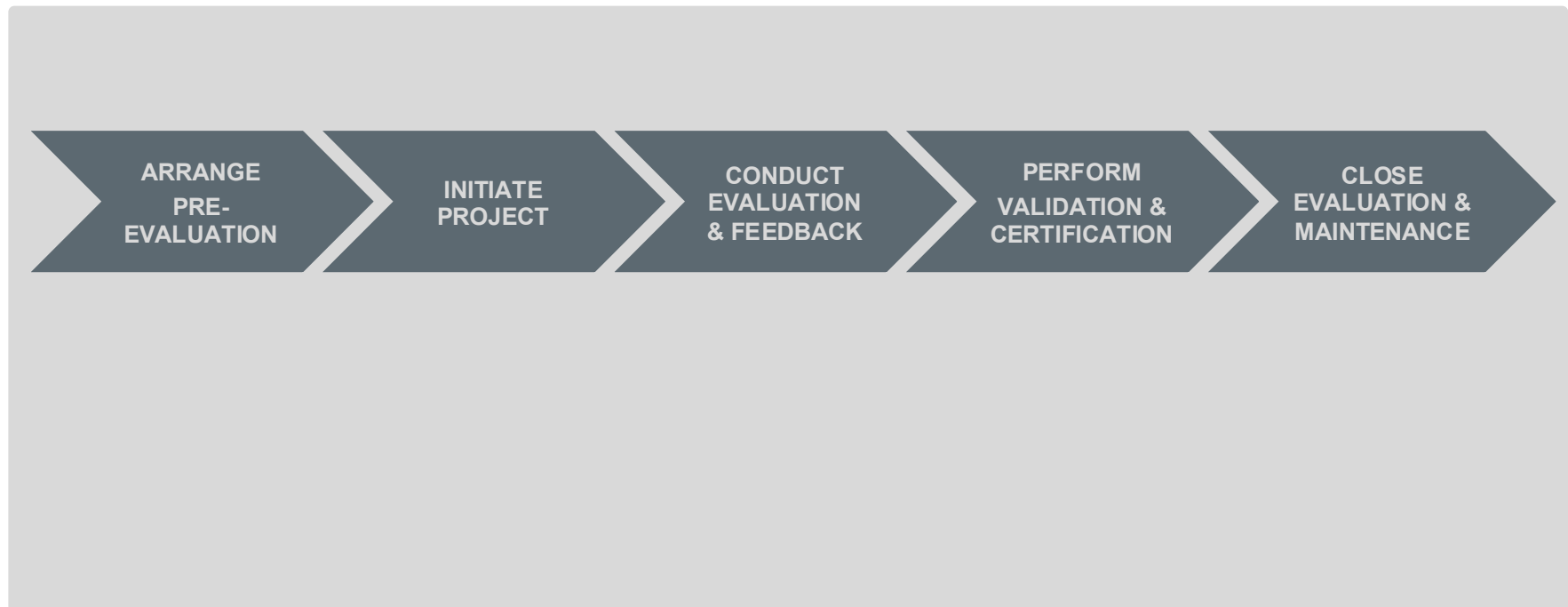
- Security requirements are selected and defined (*i.e., prioritized*)
- Market needs of (*cryptographic*) products are identified
- A recognized (*publicly available*) standard is fulfilled if a product is certified
- Dependencies between security requirements can be considered (*easily*)
- (*Cryptographic*) products can be compared relatively easy

EVIDENCE DEVELOPMENT AND EVALUATION PROCESSES

EVIDENCE DEVELOPMENT PROCESS FROM VENDORS PERSPECTIVE



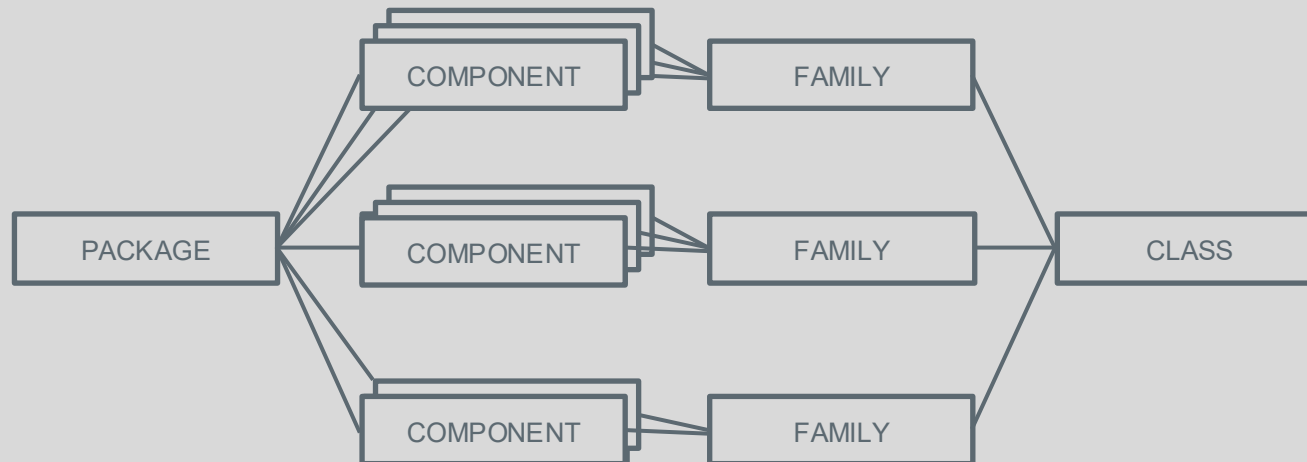
EVIDENCE EVALUATION PROCESS FROM THIRD PARTY INSTITUTION PERSPECTIVE



COMMON CRITERIA BUILDING BLOCKS AND 3 PARTS

COMMON CRITERIA 4 BUILDING BLOCKS

PACKAGES, COMPONENTS, FAMILIES, CLASSES



CLASSES, FAMILIES, COMPONENTS, AND ELEMENTS

HIERARCHICAL STRUCTURE EXPLAINED UNDER CC

Classes

- The highest ordering in classification of the structure

Families

- A family includes similar purposes

Components

- The smallest selectable units; only complete components can be selected
- Ordered under families
- Hierarchical dependencies exist between selected components

Elements

- Smallest functional units
- Hence, Elements cannot be selected (*but Components – see above*)

PART I

INTRODUCTION AND GENERAL MODEL¹

- Part I explains, how CC works.
- It provides profound definitions and gives a dictionary
- Protection Profiles (*PP*) and the Security Target (*ST*) are explained in detail

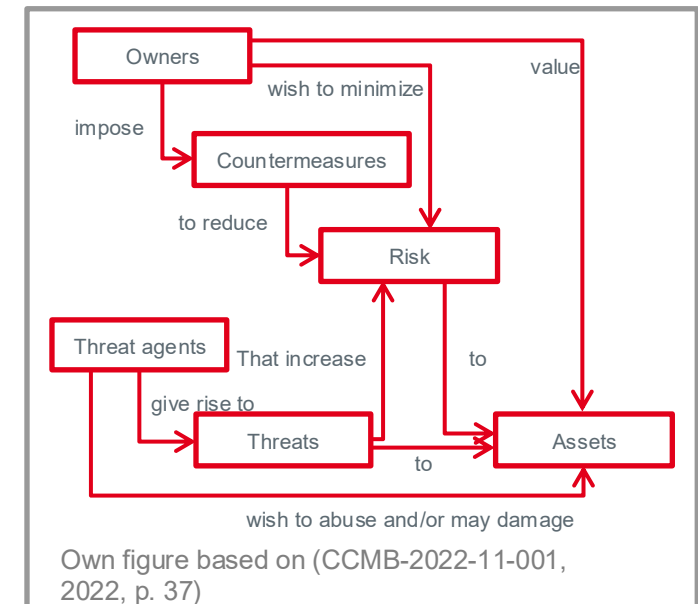
Customers can select an arbitrary instance of attributes to express the security needs.

The vendors can use the same attributes to make the security claim.

¹ cf. (CCMB-2022-11-001, 2022)

GENERAL MODEL SECURITY CONCEPTS AND RELATIONSHIPS¹

- Security in terms of asset protection;
Asset = somebody places value upon
- Feasible loss of asset (1) confidentiality, (2) integrity and (3) availability
- Threats give rise to assets, based on likelihood that a threat is realized and the impact on the asset.
- Owners may be held responsible for the asset; Threat agents put value on it.
- Countermeasures are (1) sufficient and/or correct. It includes both IT and non-IT countermeasures and reduce the risk to the asset.



¹ cf. (CCMB-2022-11-001, 2022, pp. 36-37)

RISK ANALYSIS IN CONJUNCTION WITH COMMON CRITERIA

RISKS ARE A CENTRAL CONCEPT

Information Security Risks are a Central Concept

- Risks are considered in terms of protection goals (*or security properties*)
- But risk analysis (*or risk assessment*) is not a integral part of common criteria
- Risk mitigation is evaluated (*e.g., in terms of assets such as cryptographic key generation, operation etc.*)

PROTECTION PROFILES AND PACKAGES

SECURITY REQUIREMENTS

- **Package**

A named disjoint set of security requirements containing either (1) SFR or (2) SAR.

Packages are required to be both useful and re-usable. EAL represent examples of assurance packages.

- **Protection Profile**

PP describe security requirements of a TOE type (e.g. *biometrics, firewall, IDS, IPS, PKI, QSCD, operating system, tachograph*) and thus can be used for a variety of different ST in evaluations. CC allows PPs to conform to other PPs and allowing to construct chains of PPs s.t. each is based on previous one(s).

A package can contain SFR or SAR | But not both together

SECURITY FUNCTIONAL REQUIREMENTS

SFR – REQUIREMENTS TO BE IMPLEMENTED IN PRODUCTS

Security Functional Requirements implement the functionality of products

- The TOE security objectives have to be fulfilled
- All relevant security requirements are consolidated and considered
- Abstraction to protect intellectual property is allowed to a certain extent
- Dependencies are to be taken into account as well

PART II

SECURITY FUNCTIONAL COMPONENTS¹

- Part II explains, how the CC language works.
- It provides a standard vocabulary to express security needs for customers and to express the security characteristics of a product for vendors
- Security Functional Components (*SFC*) are explained in detail

The SFCs are fragmented into families, components and elements.

The main purpose of SFCs is to (1) identify, (2) describe, and (3) categorize countermeasures against threats.

¹ cf. (CCMB-2017-04-002, 2017)

11 SECURITY FUNCTIONAL CLASSES

PARTICULAR SECURITY REQUIREMENTS

- Class FAU | Security Audit
- Class FCO | Communication
- Class FCS | Cryptographic Support
- Class FDP | User Data Protection
- Class FIA | Identification and Authentication
- Class FMT | Security Management
- Class FPR | Privacy
- Class FPT | Protection of the TSF
- Class FRU | Resource Utilization
- Class FTA | TOE Access
- Class FTP | Trusted Path/Channels

TARGET OF EVALUATION SECURITY FUNCTIONS - TSF NO ASSETS

The TSF data is mainly not considered to be an asset but security mechanisms are required to be implemented, hence protection is required

PART III

SECURITY ASSURANCE REQUIREMENTS¹

- Part III explains, how security is assured during the development process by evaluating vendor evidence by independent laboratories.
- Security is not only provided by SFR – it is necessary to build security in and integrate it into the development process of software-intensive products
- Security Assurance Components and EALs are explained in detail
- Is the product correct implemented?
- Verification of the security requirements and the claims of the vendor
- Is the product able to deal with security situations?

The SACs are fragmented into families, components and elements.

The SAR notation denotes **D**evelopers, **C**ontent, and **E**valuators requirements

9 SECURITY ASSURANCE CLASSES

PARTICULAR ASSURANCE REQUIREMENTS

- Class APE | Protection Profile Evaluation
- Class ACE | Protection Profile Configuration Evaluation
- Class ASE | Security Target Evaluation
- Class ADV | Development
- Class AGD | Guidance Documents
- Class ALC | Life-Cycle Support
- Class ATE | Tests
- Class AVA | Vulnerability Assessment
- Class ACO | Composition

7 ASSURANCE LEVELS

EAL AS OUTPUT OF THE CC PROCESS

Assurance Level		TOE Assurance Explanation
Degree of Assurance	EAL 1	Functionally Tested
	EAL 2 ¹	Structurally Tested
	EAL 3	Methodically Tested and Checked
	EAL 4 ^{1,2}	Methodically Designed, Tested and Reviewed
	EAL 5	Semi-Formally Designed and Tested
	EAL 6	Semi-Formally Verified Design and Tested
	EAL 7	Formally Verified Design and Tested

EAL 2 / EAL 4 often used for products

EAL 5 – EAL 7 require formal methods

A higher EAL does not necessarily imply more security

EVIDENCE DEVELOPMENT

5 RELEVANT PILLARS | AN OVERVIEW

5 relevant pillars in terms of Common Criteria Evidence are:

- (1) Security Target
- (2) Secure Lifecycle
- (3) Secure Development
- (4) Tests, Guidance and Vulnerability Assessment
- (5) Secure Operations

Protection Profiles are issued by official entities

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

SECURITY TARGET vs. PROTECTION PROFILE

BASIC STRUCTURE | A COMPARISON

- The structures of **PP** and **ST** are similar.
- ST has one more headline (*TOE Summary Specification*)
- The content diverges
- PP describes „*what to fulfill*“
- ST describes „*how to fulfill*“



PROTECTION PROFILES

PROTECTION PROFILE PRODUCT CLASS

A PP is an **implementation independent** description of security objectives for a family of products. It addresses threats, environmental issues and assumptions, security objectives, and security requirements. The requirements are obtained from the CC to outline a security objective. created by e.g. authority, customers

PP describes what is needed/demanded and includes:

- Introduction, containing a system identification and overview
- Product or System Family Description
- Product or System Family Security Environment
- Security Objectives
- IT Security Requirements
- Rationale ...

THREATS | SELECTED EXAMPLES

PROTECTION PROFILES

Threats (*Threats addressed by the TOE and its operational environment*)

T.Access Attackers (*e.g. human users*) could try to access functions not allowed to them (*e.g. users gaining access to calibration function*), to modify or delete user data.

T.Calibration_Parameters Human users could try to use a miscalibrated TOE (through calibration data modification, or through organisational weaknesses) to misrepresent activities (user data).

T.Clock Attackers could try to modify the internal clock of the TOE, and interfere with the correct operation of the TOE.

T.Design Attackers could try to gain illicit knowledge of the TOE design and software code, either from manufacturer's material (*e.g. through theft or bribery*) or from reverse engineering, interfere with the correct operation of the TOE.

SECURITY OBJECTIVES | SELECTED EXAMPLES

PROTECTION PROFILES

Security Objectives *(Security objectives for the TOE)*

- **O.Access** The TOE must control user access to functions and data on the basis of user type and identity.
- **O.Authentication** The TOE must authenticate users and connected entities *(when a trusted path or trusted channel needs to be established towards these users)*.
- **O.Accountability** The TOE must collect accurate accountability data.
- **O.Integrity** The TOE must maintain stored data integrity.
- **O.Output** The TOE must ensure that data output accurately reflects data measured or stored.

SECURITY OBJECTIVES

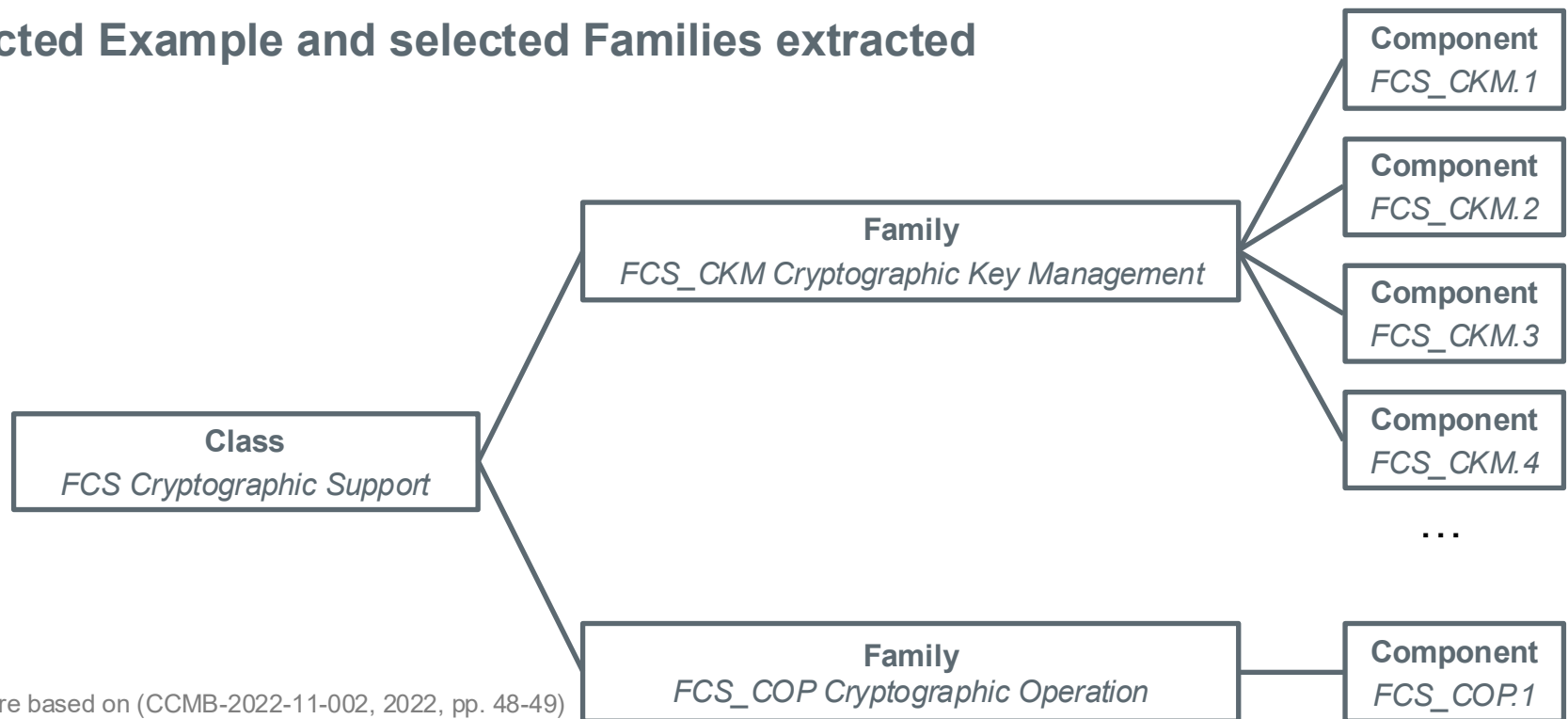
PROTECTION PROFILES

Security Objectives (*Security objectives for the operational environment*)

- **OE.Software_Upgrade** Software revisions must be granted security certification before they can be implemented in the TOE.
- **OE.Approv_Workshops** Installation, calibration and repair of recording equipment must be carried out by trusted and approved fitters or workshops.
- **OE.Controls** Law enforcement controls must be performed regularly and randomly, and must include security audits.
- **OE.Disposal** When no longer in service the TOE must be disposed of in a secure manner, which means, as a minimum, that the confidentiality of symmetric and private cryptographic keys has to be safeguarded.

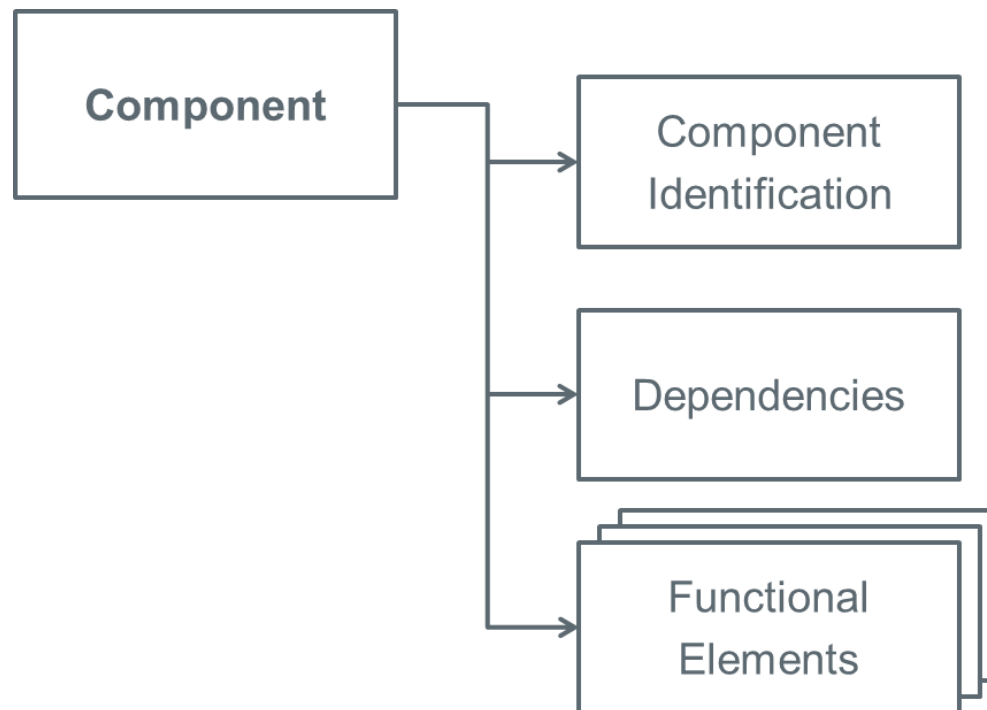
HIERARCHICAL SFC-DECOMPOSITION | CLASS FCS: CRYPTOGRAPHIC SUPPORT

Selected Example and selected Families extracted



Own figure based on (CCMB-2022-11-002, 2022, pp. 48-49)

FUNCTIONAL COMPONENT STRUCTURE



Own figure based on (CCMB-2022-11-001, 2022, p. 33)

SECURITY FUNCTIONAL REQUIREMENTS

SELECTED EXAMPLE

Security functional requirements (*Selection – for external communications*)

FCS_CKM.1 Cryptographic key generation

FCS_CKM.2 Cryptographic key distribution

FCS_CKM.4 Cryptographic key destruction

FCS_COP.1 Cryptographic operation (1: AES)

FCS_COP.1 Cryptographic operation (2: SHA-2)

FCS_COP.1 Cryptographic operation (3: ECC)

- Class FAU | Security Audit
- Class FCO | Communication
- **Class FCS | Cryptographic Support**
- Class FDP | User Data Protection
- Class FIA | Identification and Authentication
- Class FMT | Security Management
- Class FPR | Privacy
- Class FPT | Protection of the TSF
- Class FRU | Resource Utilization
- Class FTA | TOE Access
- Class FTP | Trusted Path/Channels

SECURITY FUNCTIONAL REQUIREMENTS

SELECTED EXAMPLE | cont'd

FCS_COP.1.1(1:AES) The TSF shall perform the following:

- a) pairing of a central unit and a sensor;
- b) mutual authentication between a device and a sensor;
- c) ensuring confidentiality, authenticity and integrity of data exchanged between a unit and a sensor;
- d) ensuring authenticity and integrity of data exchanged between a unit and a PED;
- e) where applicable, ensuring confidentiality of data exchanged between a central unit and a PED;
- f) ensuring authenticity and integrity of data exchanged between a central unit and storage] in accordance with a specified cryptographic algorithm [AES] and cryptographic key sizes [128, 192, 256 bits] that meet the following: [FIPS PUB 197: Advanced Encryption Standard and Appendix 11, Part B].

EXAMPLE | COMPONENTS

FCS_CKM.1 & FCS_CKM.4

FCS_CKM.1 Cryptographic key generation

Hierarchical to: No other components.

Dependencies: [FCS_CKM.2 Cryptographic key distribution, or
FCS_COP.1 Cryptographic operation]
FCS_CKM.4 Cryptographic key destruction

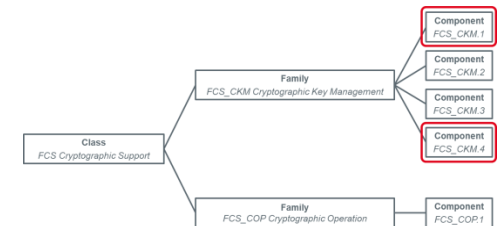
FCS_CKM.1.1 The TSF shall generate cryptographic keys in accordance with a specified cryptographic key generation algorithm [assignment: cryptographic key generation algorithm] and specified cryptographic key sizes [assignment: cryptographic key sizes] that meet the following: [assignment: list of standards].

FCS_CKM.4 Cryptographic key destruction

Hierarchical to: No other components.

Dependencies: [FDP_ITC.1 Import of user data without security attributes, or
FDP_ITC.2 Import of user data with security attributes, or
FCS_CKM.1 Cryptographic key generation]

FCS_CKM.4.1 The TSF shall destroy cryptographic keys in accordance with a specified cryptographic key destruction method [assignment: cryptographic key destruction method] that meets the following: [assignment: list of standards].



APPROVED PROTECTION PROFILES

SELECTED EXAMPLES

- Certificate Authority (*e.g. Certification Authority to compute certificates*)
- Electronic Identity Card
- Encrypted Storage (*e.g. Full Drive Encryption, USB Encryption*)
- Firewall (*e.g. Stateful Traffic Filter Firewalls*)
- IDS/IPS (*e.g. Wireless Intrusion Detection/Prevention – WIDS/WIPS*)
- Network Encryption
- Software Signature Creation Devices (SSCD)
- Trustworthy Systems Supporting Time Stamping
- TSP Cryptographic Modules
- ...

SECURITY TARGET

SECURITY TARGET PARTICULAR PRODUCT

The Security Target (*ST*) is an **implementation-dependent** document that includes a set of security requirements of a software-intensive product to be evaluated (*TOE*). It thus separates what is going to be evaluated (*i.e. TOE Boundary*) from its environment. Moreover, the ST clarifies the measures offered by the product to meet the requirements. The ST **can** fit a PP.

The TOE Boundary defines which TOE features are a subject of the evaluation.

The ST is some kind of vendor-response to security needs

SPECIFICATION OF A ST¹

1 of 2

ST Introduction (*ASE_INT*)

- ST Reference
- TOE Reference
- TOE Overview
- TOE Description

Conformance Claims (*ASE_CCL*)

- CC Conformance Claim
- PP Conformance Claim
- Package Claim
- Conformance Rationale

Security Problem Definition (*ASE_SPD*)

- Threats
- Organizational Security Policies
- *Assumptions*

**Only Assumptions in
Security Problem Definition
is Prohibited.**

All other combinations possible.

SPECIFICATION OF A ST

2 of 2

Security Objectives (*ASE_OBJ*)

- Security Objectives for the TOE
- Security Objectives for the Operational Environment
- Security Objectives Rationale

Extended Components Definition (*ASE_ECD*)

- Extended Component Definition

Security Requirements (*ASE_REQ*)

- Security Functional Requirements
- Security Assurance Requirements
- Security Requirements Rationale

TOE Summary Specifications (*ASE_TSS*)

- TOE Summary Specification

CRYPTOGRAPHIC KEY GENERATION

SELECTED SECURITY REQUIREMENTS ST

FCS_CKM.1/AES	Cryptographic key generation
FCS_CKM.1.1	The TSF shall generate cryptographic keys in accordance with a specified cryptographic key generation algorithm AES key generator, key derivation or key agreement and specified cryptographic key sizes 192 and 256 bit that meet the following: FIPS 197 and NIST Special Publication 800-38A.

FCS_CKM.1/RSA	Cryptographic key generation
FCS_CKM.1.1	The TSF shall generate cryptographic keys in accordance with a specified cryptographic key generation algorithm RSA key generator and specified cryptographic key sizes 3072 and 4096 bit ^{1,2} that meet the following: FIPS 186-4 and RFC 8017.

CRYPTOGRAPHIC KEY GENERATION

SELECTED SECURITY REQUIREMENTS ST

FIA_AFL.1	Authentication failure handling
FIA_AFL.1.1	The TSF shall detect when a TOE Maintenance configurable positive integer within 2 and $(2^{63} - 1)$ unsuccessful authentication attempts occur related to Administrators and Account Holder Authentication.
FIA_AFL.1.2	When the defined number of unsuccessful authentication attempts has been surpassed, the TSF shall suspend the Administrator and when it is an Account Holder suspend the usage of the Login_Key_Id.
FIA_UID.2	User identification before any action
FIA_UID.2.1	The TSF shall require each user to be successfully identified before allowing any other TSF-mediated actions on behalf of that user.

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

SOME VOCABULARY IN TERMS OF EVALUATION EVALUATION, CERTIFICATION, ACCREDITATION

Evaluation¹

The assessment of a Protection Profile, Security Target, or IT product against a set of Common Criteria Requirements using the Common Evaluation Methodology.

Certification²

The comprehensive technical evaluation of the security components and their compliance for the purpose of accreditation.

Accreditation³

The formal acceptance of the adequacy of a system's overall security and functionality by management.

¹ cf. (NIST NVLAP Handbook 150-20, 2005, p. 3)

² cf. (Harris and Maymí, 2016, p. 318)

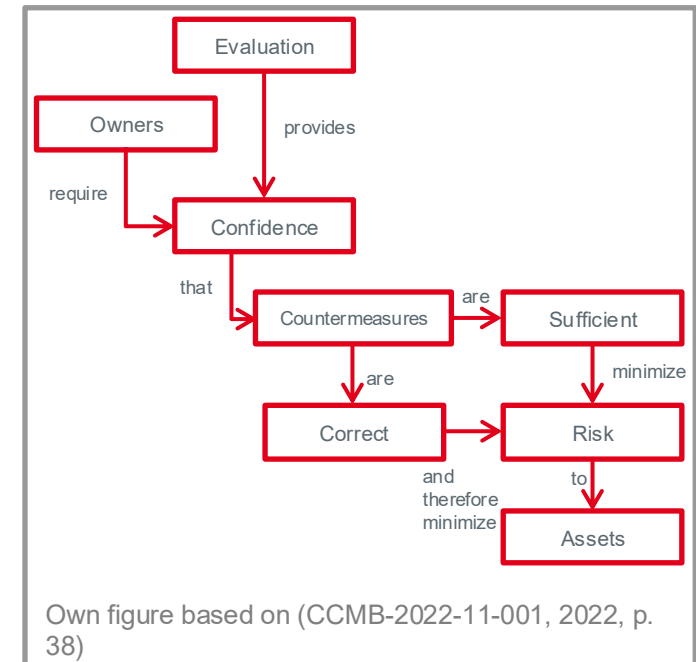
³ cf. (Harris and Maymí, 2016, p. 319)



GENERAL EVALUATION MODEL

DOCUMENT EVALUATION AND SECURITY TESTING

- Lack of expertise of owners/customers to judge sufficiency or correctness of countermeasures.
- A third party with high credibility evaluates the products and processes.
- The standardized security testing and evaluation enables to compare products and the security level.



¹ cf. (CCMB-2022-11-001, 2022, p. 38)

NICE, BUT WHY EVALUATION?

WHY DO WE EVALUATE CRYPTOGRAPHIC PRODUCTS?

- Vendors tell us lots of stories about outstanding, and world-changing products (*sometimes it might be true for several reasons*)
- What, if an independent party tests a software-intensive product based on a well-known and published methodology and derives a qualified opinion?
- The quality of the opinion relies on the integrity and on the reputation of the third-party that conducts the assessment and creates the certificate.
- Vendors can NOT self-certify

The quality of the opinion relies on both the integrity and on the reputation of the third-party that conducts the assessment and creates the certificate.

PERFORM EVALUATION TO ISSUE CC-CERTIFICATE ASSURED SECURITY LEVEL

EALs (1–7) are assigned to a product to express which requirements are met and thus define the quality with which the product was developed and the rigor of the evaluation process.

Certificates are issued under a country's national regulations and the government believes that the evaluation was performed carefully.

A certification does not necessarily imply that the evaluated product is suitable or secure. *(additional requirements: how is it installed, or maintained at the premises, configured, physical and logical security under real circumstances etc.)*

Evaluations are performed by independent laboratories. Such evaluations are both (1) time-consuming and (2) expensive. The vendors are charged for it.

CC-Certificate applies only to particular version and release of the software-intensive product in its evaluated configuration.

REAL-WORLD EXAMPLES OF CRYPTOGRAPHIC PRODUCTS EVALUATED UNDER COMMON CRITERIA

- Certification authority (CA) in PKI architecture
- Databases (e.g. *IBM DB2, Microsoft Microsoft SQL Server 2016*)
- Digital signature systems (e.g. *remote signature, “Handy-Signatur”*)
- Digital tachograph (e.g. *external GNSS, motion sensor, smart card, vehicle unit*)
- Enforcer appliance (e.g. *Symantec Network Access Control Version 12.1.2*)
- Full Drive encryption systems
- Network devices (e.g. *Cisco Adaptive Security Appliance, Cisco IOS Firewall*)
- ...

REAL-WORLD EXAMPLES OF CRYPTOGRAPHIC PRODUCTS EVALUATED UNDER COMMON CRITERIA | cont'd

- Operating systems (e.g. *MS Windows 7/10, Microsoft Windows Server 2012 R2, Red Hat Enterprise Linux 7.1, Apple iOS11.2, Vmware NSX 6.3*)
- Qualified signature creation devices (e.g. *remote QSCD*)
- Smart cards (e.g. *Gemalto, NXP Semiconductors*)
- Stateful traffic filter firewall (e.g. *SonicWall 6.2.5*)
- ...

Agenda

Introduction

Prior Art Knowledge about ISO 15408 and Common Criteria

Protection Profiles and Security Targets of Cryptographic Products

Common Criteria Evaluation of Cryptographic Products

Summary

SUMMARY

COVERED TOPICS

- **Demonstrated** the structure of the Common Criteria and ISO 15408
- **Clarified** basic **terminology** of the Common Criteria Framework
- **Explored** **security requirements** under Common Criteria
- **Presented** the basic **architecture** of **SFR and SAR**
- **Identified** **Cryptographic algorithms**, corresponding **parameters** and **strengths of mechanisms** that are applicable for certifiable products
- **Extracted** concrete **examples** of **certified cryptographic products**
- **Discussed** **experiences** from conducted projects

